Revisão do Item 2.3

Desenho detalhado dos componentes. Autor: Davi Augusto Ferreira de Carvalho. Revisão oficial do item: Isadora Yasmim da Silva.

Preparada por: Ana Luísa Pereira dos Santos, como apoio à revisão.

Base: arquivo "Documento sem título 3" (13 páginas), conferido com os Itens 1.1, 1.2, 1.3, 2.1 e 2.2. Os números de página são deste arquivo e vão mudar na integração, por isso cada ponto também diz a seção e o trecho.

Resumo

O item está completo e bem escrito. Ele cobre todos os requisitos do Item 2.1 (RF01.1 a RF01.4 e RNF02 a RNF06), os nomes das classes batem com o Item 2.2, os diagramas seguem o caso de uso e a síntese confere (6 classes com comportamento, 1 exceção e 4 objetos de dados). Há 1 ponto que depende do grupo (o 401), 5 correções de conteúdo ou consistência, 3 ajustes de redação, 6 pontos de citação para conferir e 5 ajustes de figuras, tabelas e formatação.

Cores das barras: azul é correção, amarelo é decisão do grupo, cinza é conferir na fonte e verde é ajuste de forma.

1. Decidir em grupo

1a) O 401 ainda está sem o cabeçalho WWW-Authenticate *[Decidir em grupo]*

Onde achar: *Seção "Contrato da API", Tabela 9, linha "Usuário inexistente (FA2) ou senha incorreta (FA3)" (p. 4). O mesmo 401 aparece no exemplo comentado (p. 4 e 5) e na síntese (p. 9).*

O que acontece: A regra do HTTP exige o cabeçalho WWW-Authenticate junto de qualquer 401 (RFC 9110, seção 15.5.2; confirmar o trecho). Como este item é o contrato da API, é aqui que a decisão do grupo fica registrada. O item não está errado por isso: a decisão ainda está aberta.

Sugestão: Depois que o grupo decidir, o texto muda assim. Se o 401 levar o cabeçalho: acrescentar o cabeçalho e o método indicado na Tabela 9 ou numa frase logo abaixo. Se ficar sem: acrescentar a frase "O 401 é enviado sem o cabeçalho WWW-Authenticate, porque as credenciais vão no corpo da requisição e não há um esquema de autenticação HTTP a indicar. É uma simplificação deliberada deste projeto." Nos dois casos, trocar também nos Itens 1.2, 2.1 e 2.2.

2. Correções de conteúdo e consistência

2a) 405, 415 e 404 aparecem na Tabela 9, mas o tratador não tem método para eles *[Corrigir]*

Onde achar: *Tabela 9, linha "Método diferente de POST, Content-Type diferente de JSON ou rota inexistente" e o parágrafo logo abaixo, "O TratadorExcecoes também recebe as exceções que o próprio Spring gera..." (p. 4). Compare com a Tabela 8, linha do TratadorExcecoes (p. 2), e com a Figura 8 (p. 2; código na p. 10), que só têm métodos para 400, 401 e 500, com "qualquer outra → 500".*

O que acontece: O texto diz que o Spring mantém o status 405, 415 ou 404 e o tratador só ajusta o corpo. Mas, pelo que sei do Spring, um método que trata "qualquer outra" exceção também captura essas três e as transforma em 500. Então, como o item está escrito, a tabela e o diagrama não sustentam o que o texto promete. (Confirmar na página "Exceptions", SPRING s.d.g.)

Sugestão: Acrescentar um método ao TratadorExcecoes para esses casos e atualizar os três lugares. Na Tabela 8, em Operações principais: "método, Content-Type ou rota não aceitos → mantém o status do Spring (405, 415 ou 404); qualquer outra → 500". No código da Figura 8, uma linha a mais no TratadorExcecoes:

```
      + erroDeProtocolo(e) : RespostaErro [405, 415, 404]
```

Na frase do 405, dizer que o status e os cabeçalhos do Spring são mantidos: a RFC 9110 exige o cabeçalho Allow em toda resposta 405 (seção 15.5.6; confirmar).

2b) "Quatro códigos" no Item 1.2 não bate com a Tabela 9 *[Corrigir]*

Onde achar: *Item 1.2, parágrafo sobre o código de status: "Na API de autenticação são previstos quatro códigos, conforme o contrato do Item 2.3". Compare com a Tabela 9 do Item 2.3 (p. 4).*

O que acontece: A Tabela 9 lista 200, 400, 401, 500, 405, 415, 404 e, pelo Nginx, 502 e 504. O Item 1.2 manda o leitor para o contrato dizendo que são quatro, e o contrato mostra mais.

Sugestão: Trocar no Item 1.2 para "quatro códigos principais: 200, 400, 401 e 500" e acrescentar "o contrato do Item 2.3 inclui ainda 405, 415 e 404". É uma mudança na parte da Isadora; combinar com ela.

2c) O exemplo do 2.3 usa id 1, e o do Item 1.2 usa id 42 *[Corrigir]*

Onde achar: *Tabela 9, linha 200 OK (p. 4), e exemplo comentado (p. 4 e 5): "{"id": 1, ...}". Compare com o Item 1.2, exemplo da resposta 200: "{"id": 42, ...}", com Content-Length 69.*

O que acontece: O próprio 2.3 diz que as mensagens completas estão no Item 1.2. Se o exemplo muda de id entre um item e outro, parece que são respostas de usuários diferentes e quem confere pode estranhar.

Sugestão: Usar id 42 no 2.3 (Tabela 9 e exemplo comentado), igual ao Item 1.2. O corpo fica com o mesmo tamanho do Content-Length de 69 bytes.

2d) @RestControllerAdvice no 2.3 e @ControllerAdvice no 2.2 *[Corrigir]*

Onde achar: *Tabela 8, linha do TratadorExcecoes (p. 2) e Figura 8 (<<RestControllerAdvice>>). No Item 2.2: seção "Tratamento de erros" e o rótulo da Figura 7. No Item 1.3: parágrafo do tratador de exceções.*

O que acontece: As duas anotações existem, mas o leitor vê nomes diferentes para a mesma classe. A página do Spring (SPRING s.d.i) diz que @RestControllerAdvice é a forma abreviada de @ControllerAdvice com @ResponseBody, e para uma API JSON ela é a escolha mais precisa.

Sugestão: No 2.3, acrescentar uma frase: "@RestControllerAdvice é a variante de @ControllerAdvice que escreve o retorno no corpo da resposta (SPRING, s.d.i)." No 2.2 (que é minha parte), trocar para @RestControllerAdvice no texto e no rótulo da Figura 7. No 1.3, o Davi pode fazer o mesmo.

2e) O Item 2.1 ainda diz "Argon2id ou bcrypt" *[Corrigir]*

Onde achar: *Item 2.1, Tabela 5, linha RNF02. Compare com o 2.3, seção "Verificação da senha" (p. 8) e Tabela 10, coluna hash_senha (p. 7).*

O que acontece: O 2.3 decide por Argon2id, com parâmetros definidos. O RNF02 do 2.1 ainda deixa o bcrypt como alternativa. A fonte (OWASP) também recomenda Argon2id em primeiro lugar.

Sugestão: No 2.1, trocar por "Argon2id" (ou "Argon2id, conforme o Item 2.3"). É a mesma correção que já tínhamos apontado no 2.1; agora ela tem apoio no próprio projeto.

2f) "Sem comportamento próprio" e a senha escondida nos objetos *[Ajuste]*

Onde achar: *Seção "Classes e responsabilidades", fim do primeiro parágrafo (p. 1): "eles não têm comportamento próprio". Depois, após a Tabela 8 (p. 3): "escondem a senha e o hash na sua representação em texto... (RNF04)".*

O que acontece: Esconder o valor no texto exige um método, então os objetos têm um pequeno comportamento. Além disso, o RNF04 trata das respostas, e não dos registros de log.

Sugestão: Trocar "não têm comportamento próprio" por "não têm regra de negócio". Na segunda frase, trocar "(RNF04)" por "(complementa o RNF04)" ou explicar que a medida evita vazar a senha nos logs.

2g) "Um ataque não consegue inserir, alterar ou apagar" é forte demais *[Ajuste]*

Onde achar: *Seção "Modelo de dados", parágrafo depois do SQL (p. 8): "um erro ou um ataque na aplicação não consegue inserir, alterar ou apagar usuários".*

O que acontece: É verdade para o usuário app_autenticacao, mas ele ainda lê a tabela inteira, inclusive os hashes. A frase pode parecer garantir mais do que garante.

Sugestão: Acrescentar "mas ainda pode ler a tabela, por isso o hash precisa ser forte (RNF02)".

2h) O tamanho 254 do e-mail aparece sem explicação *[Ajuste]*

Onde achar: *Tabela 10, linha email, coluna Tipo (p. 7).*

O que acontece: O número é usual, mas o leitor não sabe de onde vem. Não é erro; é um detalhe que a professora pode perguntar.

Sugestão: Opcional: acrescentar "(tamanho máximo usual de um endereço de e-mail)" ou citar a norma de e-mail (RFC 5321), depois de confirmar o número.

3. Fontes e citações para conferir

As quatro fontes novas deste item existem. Os pontos abaixo são afirmações que podem estar além do que a fonte diz, ou que eu não consegui abrir.

3a) "Sal de 16 bytes" atribuído à OWASP *[Conferir]*

Onde achar: *Seção "Verificação da senha", segundo parágrafo (p. 8): "gera um sal aleatório de 16 bytes (128 bits) para cada senha... (OWASP, s.d.c)".*

O que acontece: A OWASP recomenda um sal único por senha. O tamanho de 16 bytes é o padrão do codificador do Spring Security, e não da OWASP. A citação sustenta a primeira parte da frase e não o número.

Sugestão: Citar o Spring (SPRING s.d.k ou a documentação da classe Argon2PasswordEncoder) para o 16, ou retirar o número e deixar "sal aleatório e único para cada senha (OWASP, s.d.c)".

3b) Argon2id "lento e exige muita memória" (SPRING s.d.k) *[Conferir]*

Onde achar: *Seção "Verificação da senha", primeiro parágrafo (p. 8).*

O que acontece: Não consegui abrir a página de Password Storage do Spring Security. A afirmação é correta em geral, mas precisa estar nessa página.

Sugestão: Abrir a página e confirmar que ela descreve o Argon2 como lento e que exige muita memória. Se não disser, citar a OWASP (s.d.c), que diz isso.

3c) "Mesmo processo em todas as tentativas" (OWASP s.d.b) *[Conferir]*

Onde achar: *Seção "Verificação da senha", parágrafo "O tempo de resposta também precisa ser protegido" (p. 9).*

O que acontece: Esse é o ponto do Authentication Cheat Sheet que eu também não pude abrir, desde o Item 2.1. Ele sustenta o RNF03 e o RNF06.

Sugestão: Quem abrir a página confirma os trechos sobre mensagem genérica e tempo de resposta semelhante, e anota a seção na citação.

3d) "É esse índice que o planejador usa" *[Conferir]*

Onde achar: *Seção "Modelo de dados", logo após a Tabela 10 (p. 8).*

O que acontece: O planejador escolhe o caminho mais barato. Em uma tabela pequena ele pode preferir ler a tabela inteira. A fonte (POSTGRESQL s.d.f) confirma que o índice é criado, mas não que ele será sempre usado. O Item 1.3 diz "como usar o índice", com cautela.

Sugestão: Trocar "é esse índice que o planejador usa" por "é esse índice que o planejador pode usar".

3e) Sommerville sem página *[Conferir]*

Onde achar: *Primeiro parágrafo do item (p. 1), citação (SOMMERVILLE, 2018) para a notação UML.*

O que acontece: A citação não diz onde. Em uma citação indireta isso é aceitável, mas o revisor não consegue conferir. O capítulo sobre modelagem de sistemas é o provável, mas não abri o livro.

Sugestão: Acrescentar o capítulo ou a página, com o mesmo ano nos Itens 2.1, 2.2 e 2.3.

3f) Lista de referências deste arquivo *[Conferir]*

Onde achar: *Páginas 9 e 10, lista de referências.*

O que acontece: O ANTHROPIC (2026f) e a Seção VI.7 do Apêndice VI não aparecem na lista. As entradas POSTGRESQL s.d.f e SPRING s.d.k trazem a marca "(nova)". As letras OWASP s.d.b e s.d.c mudam na consolidação.

Sugestão: Deixar essas marcas para a Ana tratar na consolidação, que já está combinada. Só conferir que "(nova)" e qualquer "[CONFERIR]" não vão para o PDF final.

4. Figuras, tabelas e formatação

4a) Figura 8 está pequena e confusa *[Ajuste]*

Onde achar: *Seção "Classes e responsabilidades", Figura 8 (p. 2).*

O que acontece: A imagem ocupa a largura da página, mas o diagrama é largo e os rótulos ficam em letra muito pequena. As linhas tracejadas se cruzam bastante, principalmente as que ligam as classes de modelo (devolve, recebe, cria).

Sugestão: Duas opções, que podem ser combinadas. Gerar de novo com fonte maior e dar à figura uma página própria. E tirar do diagrama as setas tracejadas para o pacote Modelo (recebe, devolve, cria), já que a Tabela 8 e o texto dizem isso. Isso deixa só as chamadas entre camadas e a exceção.

4b) Palavras quebradas no meio nas Tabelas 8, 9 e 10 *[Ajuste]*

Onde achar: *Tabela 8 (p. 2 e 3): "ControladorAutenti|cacao", "ServicoAutenticac|ao", "ConfiguracaoSenh|a", "FalhaAutenticacao|Exception", "Persistênc|ia", "Requisito|s (Item 2.1)" no cabeçalho. Tabela 9 (p. 4): "Unauthorize|d". Tabela 10 (p. 7): "VARCHAR(254|)".*

O que acontece: As colunas são estreitas para os nomes. O leitor lê como erro de digitação, e os termos técnicos ficam difíceis de localizar.

Sugestão: Reduzir a fonte das tabelas para 9 pt, alargar as colunas de nomes e de status e encurtar o cabeçalho para "Requisitos". Na Tabela 8, se ainda faltar espaço, tirar a coluna Camada, já que a Figura 8 e o texto agrupam as classes por camada.

4c) Exemplo comentado com lacunas no texto *[Ajuste]*

Onde achar: *Seção "Contrato da API", "Exemplo comentado", parágrafo que começa em "Se a senha conferir..." (p. 4 e 5).*

O que acontece: O parágrafo está justificado e contém trechos JSON sem espaço para quebrar, então aparecem grandes lacunas entre as palavras. Além disso, "errada" está entre aspas sem necessidade.

Sugestão: Colocar os corpos JSON em fonte de código, em linhas separadas, como o Item 1.2 faz, e escrever "com uma senha incorreta" em vez de "errada" entre aspas.

4d) Quebra de linha em uma mensagem do código da Figura 10 *[Ajuste]*

Onde achar: *Apêndice I, código da Figura 10, última linha de resposta "Erro interno. Tente novamente mais / tarde." (p. 12 e 13).*

O que acontece: A linha do código aparece quebrada no meio da frase. Se a quebra existir no texto de verdade, o PlantUML interpreta como uma nova linha e o diagrama pode dar erro. Se for só a largura do PDF, não há problema.

Sugestão: Testar o código copiado do PDF. Se der erro, usar \n dentro da mensagem ou encurtar o texto.

4e) Termos estrangeiros e código *[Ajuste]*

Onde achar: *Texto em geral, por exemplo "records", "log", "script de carga", "hash".*

O que acontece: O documento usa itálico para termos estrangeiros pouco comuns (como endpoint e framework) e fonte de código para nomes de classes e anotações. Alguns termos aqui ainda estão sem a marcação.

Sugestão: Aplicar o mesmo padrão em todo o item. Termos já consagrados em português (hash, log) não precisam de itálico; records e script de carga podem ter.

5. O que já está conforme

Conferi e está correto: o contrato 400, 401 e 500 bate com os fluxos FA1, FA2, FA3 e FE1 do Item 2.1; a mensagem de erro e o corpo do 401 são iguais aos do Item 1.2; as classes e as camadas batem com a Figura 7 e a Tabela 6 do Item 2.2; a regra de só chamar a camada abaixo é respeitada na Figura 8; a Tabela 5 do Item 2.1 (coluna "Onde é tratado") encontra tudo o que promete aqui (algoritmo, parâmetros, coluna hash_senha, objeto de resposta, hash fictício); a ligação com a Figura 5 do Item 1.3 e com o índice da coluna email é coerente; a numeração das Figuras 8 a 10 e das Tabelas 8 a 10 segue a sequência; o NIST (sal de pelo menos 32 bits, esquema de hash com fator de custo) e a configuração mínima do Argon2id da OWASP (19 MiB, 2 iterações, paralelismo 1) conferem com as fontes que eu li antes; o exemplo de hash tem o formato certo.

6. Checklist final

- ☐ Decisão do 401 registrada (1a) e trocada nos Itens 1.2, 2.1, 2.2 e 2.3
- ☐ Método do TratadorExcecoes para 405, 415 e 404 na Tabela 8, na Figura 8 e no texto (2a)
- ☐ Item 1.2: "quatro códigos" ajustado (2b)
- ☐ Exemplos com id 42 (2c)
- ☐ @RestControllerAdvice igual nos Itens 1.3, 2.2 e 2.3 (2d)
- ☐ RNF02 do Item 2.1 com Argon2id (2e)
- ☐ Ajustes de redação 2f, 2g e 2h
- ☐ Citações 3a a 3e conferidas nas fontes
- ☐ Figura 8 legível e tabelas sem palavras quebradas (4a, 4b)
- ☐ Código da Figura 10 testado (4d)
- ☐ Esta revisão e as correções feitas registradas no apêndice de revisões, com a Isadora como revisora oficial do item